PROJECT

Incident Response Plan

Work through a real ransomware scenario using the NIST 6-step Incident Response framework

Your Name:	**Date:**	**Incident Scenario:**
Tyler Arend	**9/12/2026**	Ransomware Attack

What is this project?

When a cyberattack happens, security teams follow a structured plan to respond. This is called Incident Response (IR). The most widely used framework is NIST 800-61, which has 6 steps.

In this project, you are the lead security analyst for Riverdale Community Hospital.
A ransomware attack has just been discovered. You will work through ALL 6 steps of the NIST Incident Response framework and document exactly what you would do.
This template guides you through each step with questions and hints.

The Scenario: Ransomware at Riverdale Community Hospital

INCIDENT ALERT - Monday 7:43 AM

You arrive at work as the Security Analyst for Riverdale Community Hospital (400 beds, 800 staff).

A nurse calls the IT helpdesk: 'My computer just showed a weird message saying all my files are encrypted and I need to pay Bitcoin to get them back. None of my patient files open anymore.'

Within the next 30 minutes, you receive 3 more calls:

- The radiology department's imaging system is completely locked
- The hospital's billing system shows the same ransom message
- The SIEM is sending hundreds of alerts about unusual file activity across the network

The ransom note demands $500,000 in Bitcoin within 72 hours or all files will be permanently deleted.

Patient care is at risk. What do you do?

NIST 800-61 Incident Response Framework - Quick Reference:

Step 1: PREPARATION - Having the right tools, policies, and team ready BEFORE an incident
Step 2: DETECTION & ANALYSIS - Confirming the incident is real and understanding what happened
Step 3: CONTAINMENT - Stopping the attack from spreading further
Step 4: ERADICATION - Removing the malware and fixing the vulnerability that let attackers in
Step 5: RECOVERY - Restoring systems to normal operation
Step 6: LESSONS LEARNED - After everything is resolved, reviewing what happened and improving

You will work through ALL 6 steps below. Use the hints in each section to guide your thinking.

Step 1: Preparation

Preparation happens BEFORE incidents. Answer these questions about what Riverdale Hospital SHOULD have had in place.

STEP 1 **Preparation**	*Even though this step happened before the attack, it is important to assess what was in place , and what might have been missing.*

What policies and plans should the hospital have had ready BEFORE this attack?

The hospital should have an Incident Response Policy, a Backup Policy, and a Disaster Recovery Plan in place before this incident occurred. An Incident Response Policy and Disaster Recovery Plan would contain a pre-approved plan of action in the event of a cyberattack, saving time and stress for if an attack were to occur. A Backup Policy would allow for operations to continue as normal for the hospital, as all of their important files, such as the patient's files, would still be accessible.

Sources:

Incident Response Plan (IRP) Basics

Cyber Recovery vs. Disaster Recovery: What's the difference? | IBM

What security tools should have been deployed and monitoring the network?

The network for this hospital should have had a SIEM, antivirus, IDS/IPS, email filtering, and patch management as a part of their cybersecurity. While the hospital already seems to have a SIEM solution, this only alerts of strange activity, seemingly to someone physically present in the building, meaning any activity occurring overnight will go unnoticed by the IT team and will not be prevented by the SIEM solution. A IPS alongside the SIEM would help prevent strange activity from executing on the network, even without any IT staff present. To alleviate the load on the SIEM and IPS, all systems throughout the hospital should have an up-to-date antivirus, email filtering system, and system patches.

Who should be on the Incident Response Team (IRT)?	What training should hospital staff have received?
Security Analysts, IT Manager, assigned Incident Manager, assigned Tech Manager, assigned Communications Manager, and Legal/Attornies	*Phishing and malware awareness and prevention, incident response training*

Step 2: Detection & Analysis

STEP 2 **Detection & Analysis**	*Your job here is to confirm this IS a real incident, understand the scope, and gather evidence.*

What are the Indicators of Compromise (IoCs) in this scenario? List everything.

The IoCs are the ransom messages on at least two department's systems (nurses and billing), the patient files being locked, the radiology systems being locked, and the SIEM solution sending alerts.

How did the ransomware likely get in? (Attack Vector)	How would you estimate the scope? How many systems are affected?
Within a hospital environment, the attack vector was likely unpatched software, a phishing email, or a USB drive. Since hospitals run at all hours, systems cannot go down for any extended period of time that might be required to do a system update, leaving them exposed to vulnerabilities. With so many entering and exiting a hospital, staff as well as patients connecting to the hospital network can introduce malware from their devices. Finally, this number of people within a hospital can make it difficult to keep systems physically secure, allowing for an upset patient or their family to plug in unknown USBs into the hospital systems.	*Reports from staff to assess the departments affected, SIEM logs to evaluate which systems were affected and by what, and a network scan to observe the behaviour of the attack.*

What is your severity rating for this incident and why? (Low / Medium / High / Critical)

Critical; since patient files are affected, limiting their care, this attack might result in deaths of patients.

Step 3: Containment

STEP 3 **Containment**	*Stop the bleeding. Your goal is to prevent the ransomware from spreading to more systems.*

SHORT-TERM Containment (do RIGHT NOW):	**LONG-TERM Containment (days 1-3):**
Isolate infected machines, disable network and outbound traffic from these machines, and scan systems not showing immediate signs of infection to verify they are safe.	*Segment network by department, reset credentials of safe systems, update firewall with more strict rules, DMZ for systems that need access to the internet.*

This is a hospital. Patients could be in danger if systems are offline. How do you balance containment with patient safety?

After systems are verified to be safe and their credentials have been reset, these remaining systems will need to be shared among nurses or medical staff while the other systems are restored, or backup systems will need to be used. If there is no backup infrastructure, patients needing more immediate care should have more access to systems required for their care.

Step 4: Eradication

STEP 4 **Eradication**	*Remove the threat completely. This means removing malware AND closing the door they used to get in.*

What specific actions do you take to remove the ransomware from infected systems?

Run malware removal tools, delete suspicious scheduled tasks, registry keys, or credentials, and reimage machines if needed as a last resort.

How do you find and fix the VULNERABILITY that allowed the ransomware to enter?

Reviewing the logs on each system should reveal how the attacker entered the systems. For example, if systems repeatedly show network traffic from port 23 when the attack started, this points to the attacker using an open Telnet port to access the systems. In this case, port 23 should be closed on the network to prevent further entry, as well as future attacks.

What user accounts need to be reviewed or reset?	How do you VERIFY eradication was successful before moving on?
All accounts should have their passwords reset, and all accounts should be reviewed. Admin accounts should also be reset and reviewed.	*Monitoring the systems while they are in quarantine to see if any new suspicious behaviour occurs. If the system continues to behave strangely, despite running malware removal tools and running antivirus software, something was missed deeper in the system.*

Step 5: Recovery

STEP 5 **Recovery**	*Restore systems to normal operation. This is not just 'turn it back on' , you need to do it carefully.*

How do you restore the encrypted data? What do you restore it from?
In 2026 most data is backed up to the cloud with full, differential, and/or incremental backups. Assuming this hospital backs up their data this way, restoring the data with the most recent back up is the simplest way to gain access to their data. For a hospital, their backups should be routine at the end of each day. If backups occur at midnight each night, and the nurse in the scenario calls at 7:43am, data between midnight and 7:43am might be lost. *Source:* *Types of Backup: Full, Incremental, and Differential | Unitrends*

FIRST to restore (most critical for patient care):	SECOND to restore:	LAST to restore (least critical):
Patient care systems, ICU monitors, and radiology systems	*Front desk/reception desk*	*Billing and HR systems*

How do you monitor systems after recovery to make sure the attackers have not come back?
Monitoring SIEM solution, adding new detection rules to SIEM, setting a behavioural baseline for systems, monitor IPS, firewall, and antivirus software.

Step 6: Lessons Learned

STEP 6 **Lessons Learned**	*After the dust settles, you hold a review meeting. This step prevents the same incident from happening again.*

What were the TOP 3 things that went wrong or could have been prevented?

1. *Backups were unavailable or not tested*
2. *SIEM could not prevent attacks, only detect them*
3. *Staff were not trained on ransomware or malware attacks*

What specific security improvements would you recommend to hospital leadership?

Segment network by department, regular password changes, update firewall with more strict rules, DMZ for systems that need access to the internet, implement IPS in addition to SIEM, employee training on cybersecurity and malware, regular patching of systems, stricter management of WiFi access, and stricter access to physical hardware that might allow foreign USBs to be plugged in.

Should the hospital pay the ransom? Why or why not?

Ransom should only be paid as a last resort option. If the hospital is unable to get things secured and recovered in a timely manner, paying the ransom might be the difference between life and death for their patients. Since it isn't guaranteed the attacker will give up their control of their systems after the payment, it is better to risk it when all other options have been tried and failed than risk the death of patients.

Who needs to be notified about this breach (outside the hospital)?

Law enforcement, patients/clients, other medical facilities that may be impacted by the breach, insurance companies, and attorneys.

Reflection

Which step was most challenging to think through?

The questions "How do you balance containment with patient safety?" and "Should the hospital pay the ransom? Why or why not?" were the hardest to answer, since they don't have a right or wrong answer, and are ethical questions rather than technical.

What Security+ concept did this scenario help you understand better?

IoC vs IoA, containment vs eradication, backup types, SIEM vs IPS vs IDS

Before You Submit: Checklist

Check each item when complete:

[✔] I completed ALL 6 NIST steps
[✔] I explained my reasoning, not just listed actions
[✔] I addressed the patient care vs. containment tension in Step 3
[✔] I stated whether to pay the ransom and why
[✔] I listed who needs to be notified (Step 6)
[✔] I completed the reflection section

Portfolio tip: Title this: 'Incident Response Plan - Ransomware Scenario - [Your Name]'
Talking point: 'I worked through a ransomware tabletop exercise using the NIST 800-61 framework, covering all 6 phases from preparation through lessons learned in a healthcare context.'